

AN TOÀN THÔNG TIN (INSE330380)

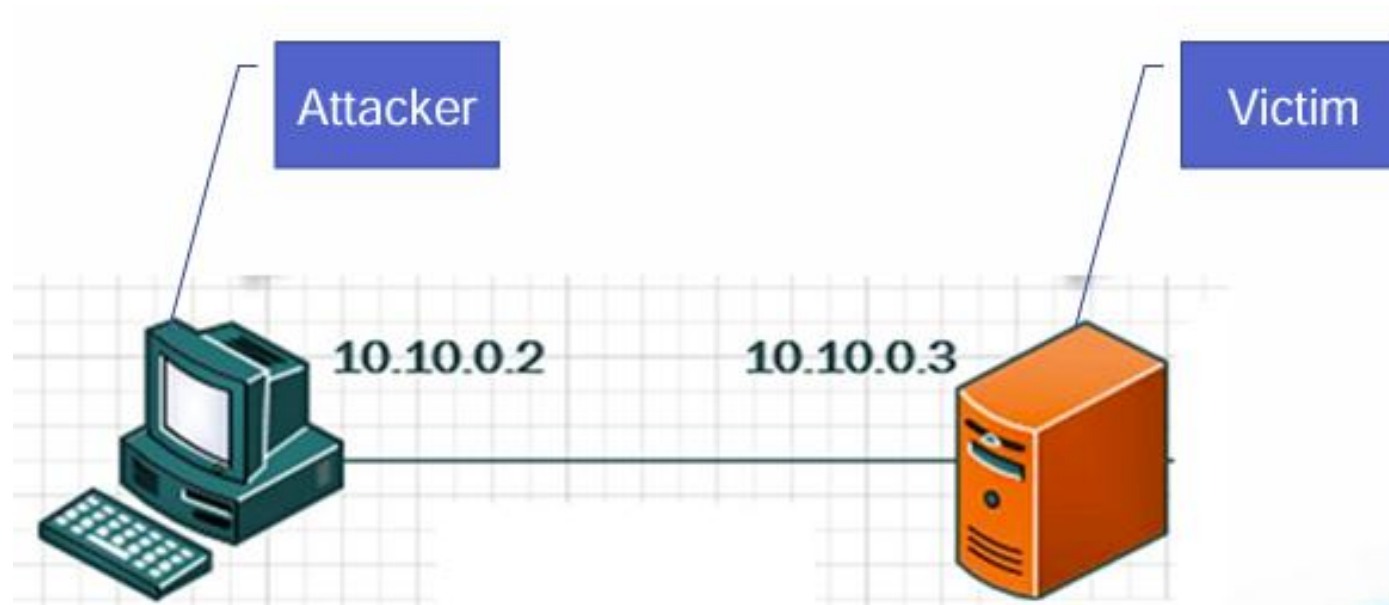
BÀI LAB CHƯƠNG VI FIREWALL – IDS/IPS

Ths. ĐỖ MINH HẬU

Sinh viên được thực hành trực tiếp về:

- ☐ Việc xây dựng hệ thống Firewall dựa vào opensource IPTable
- ☐ Cấu hình Firewall
- ☐ Kiểm soát các luồng dữ liệu vào ra
- ☐ Việc xây dựng hệ thống IDS-IPS dựa vào opensource Snort
- ☐ Cấu hình Snort
- ☐ Thực hiện các tấn công phổ biến: DoS, Probe, Scan port, SQL Injection,....
- ☐ Giám sát & phát hiện các tấn công

- ❑ Cài đặt một máy Attacker: có HĐH Kali Linux (có thể dùng VMWare để tạo máy ảo)
- ❑ Cài đặt một máy vừa là Victim vừa là bảo vệ (Firewall hoặc IDS): có HĐH Ubuntu hoặc CentOS (dùng máy ảo)
- ❑ Hai máy kết nối với nhau



Firewall cho Linux: Netfilter and iptables xây dựng các khối của một Framework bên trong Linux 2.4.x and 2.6.x kernel.

☐ Có các chức năng:

- packet filtering,
- network address [and port] translation (NA[P]T) and
- other packet mangling.

Version

- Ipfwadm : Linux kernel 2.0.34
- Ipchains : Linux kernel 2.2.*
- Iptables : Linux kernel 2.4.*

☐ Kiểm tra gói tin có trạng thái.

- Tường lửa theo dõi từng kết nối đi qua nó,
- Đây là một tính năng quan trọng trong việc hỗ trợ FTP và VoIP đang hoạt động.

☐ Lọc các gói tin dựa trên địa chỉ MAC IPv4 / IPv6

- Rất quan trọng trong WLAN và các môi trường tương tự.

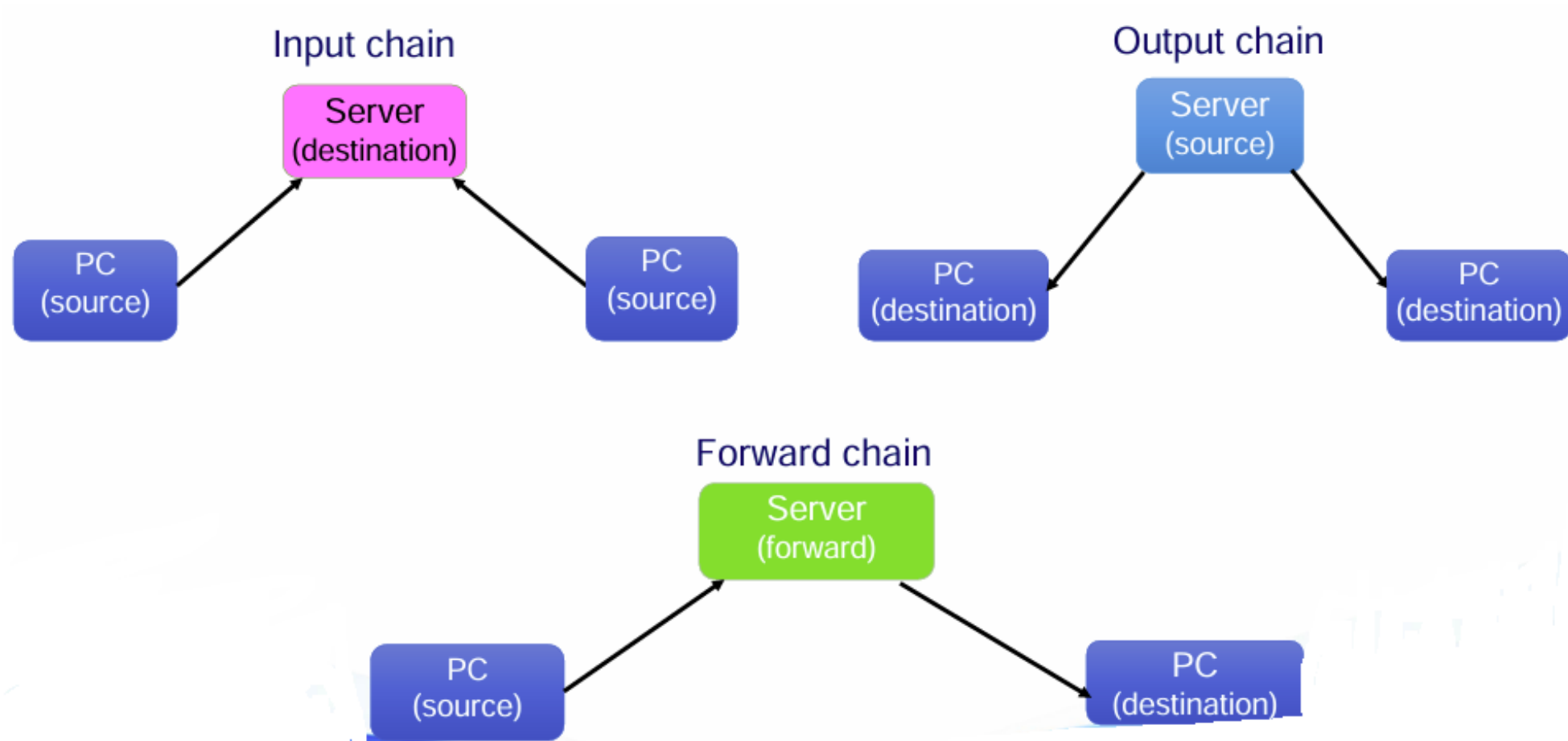
☐ Lọc các gói tin dựa trên giá trị của các cờ trong tiêu đề TCP

- Hữu ích trong việc ngăn chặn các cuộc tấn công sử dụng các gói tin không đúng định dạng và hạn chế quyền truy cập.

☐ Biên dịch địa chỉ mạng và Biên dịch cổng NAT/NAPT

- Xây dựng DMZ và các môi trường NAT linh hoạt hơn để tăng cường bảo mật

- ❑ Nguồn và các chức năng định tuyến và chuyển đổi dự phòng có trạng thái
 - Định tuyến lưu lượng hiệu quả hơn và nhanh hơn so với các bộ định tuyến IP thông thường.
- ❑ Ghi nhật ký hệ thống các hoạt động mạng
 - Cung cấp tùy chọn điều chỉnh mức độ chi tiết của báo cáo
- ❑ Tính năng giới hạn tốc độ
 - Giúp chặn một số loại tấn công từ chối dịch vụ (DoS).
- ❑ Thao tác gói tin (làm méo mó) như thay đổi các bit TOS/DSCP/ECN của tiêu đề IP
 - Đánh dấu và phân loại các gói tin phụ thuộc vào các quy tắc. Bước đầu tiên trong QoS.



- ❑ Download from: <http://www.netfilter.org/downloads.html>
- ❑ Documentation: <http://www.netfilter.org/documentation/index.html>
- ❑ Install from sources or rpm:

rpm -ivh iptables-1.2.9-1.0.i386.rpm

tar xvfz iptables-1.2.9.tar.gz ; ./configure ; make ; make install

- ❑ Các modules chức năng bổ sung vào IPtables:

Various proxy modules, for example ftp and h323

Modules must be loaded into kernel

modprobe module

insmod module

- ❑ Updated and modules: <http://ftp.netfilter.org/pub/patch-o-matic-ng/snapshot/>

❑ Sử dụng các lệnh để điều khiển IPTable

- Starting IP tables: `service iptables start`
- Stopping IP tables: `service iptables stop`
- Restarting IP tables: `service iptables restart`
- Checking IP tables status (rulechains): `service iptables status`

❑ Để cấu hình iptables để bắt đầu khi khởi động, hãy sử dụng lệnh `chkconfig`:

- `chkconfig iptables on`

Thao tác trên các chuỗi luật (rule chains):

- ❑ Để hiển thị tất cả các chain hiện tại: `iptables --list`
- ❑ Để xóa tất cả các chain hiện tại: `iptables --flush`
- ❑ Tạo chain mới: `iptables -N chain_name`
- ❑ Xóa tất cả các rules trong chain: `iptables -F chain_name`
- ❑ Xóa chain rỗng: `iptables -X chain_name`
- ❑ Thiết lập chính sách chain: `iptables -P chain_name target`
- ❑ Quản lý các rule trong một chain
 - Thêm: `iptables -A chain_name rule_spec`
 - Xóa: `iptables -D chain_name rule_num`
 - Chèn: `iptables -I chain_name [rule_num] rule_spec`

Một số option

- ❑ -p —Đặt giao thức IP cho rule, có thể là icmp, tcp, udp hoặc tất cả, để khớp với mọi giao thức được hỗ trợ.
 - Giao thức tcp: -p tcp -sport <port>; -p tcp -dport <port>, -p tcp -sync
 - Giao thức udp: -p udp -sport <port>
 - Giao thức icmp: -p icmp -icmp-type <type>
- ❑ -s (-d) — Đặt nguồn (đích) cho một gói tin cụ thể
- ❑ -i — Đặt giao diện mạng đến (eth0 hoặc ppp0), có thể được sử dụng với các chain INPUT và FORWARD khi được sử dụng với bảng FILTER và chain PREROUTING trong bảng NAT
- ❑ -j —Yêu cầu iptables nhảy đến 1 mục tiêu cụ thể khi một gói tin khớp với một rule cụ thể.
- ❑ -o —Đặt giao diện mạng đi cho một rule cụ thể và chỉ có thể được sử dụng với các chuỗi OUTPUT và FORWARD trong bảng FILTER và chuỗi POSTROUTING trong bảng NAT

Khi một gói tin khớp với một rule cụ thể, rule đó có thể chuyển hướng gói tin đến một số mục tiêu khác nhau để quyết định số phận của gói tin và có thể thực hiện các hành động bổ sung, như:

- ☐ ACCEPT —Cho phép gói tin di chuyển thành công đến đích hoặc chuỗi khác.
- ☐ DROP —Xóa gói tin mà không phản hồi cho người yêu cầu.
- ☐ QUEUE —Gói tin được xếp hàng để ứng dụng không gian người dùng xử lý.
- ☐ RETURN —Dừng kiểm tra gói tin so với các rule trong chuỗi hiện tại.
- ☐ REJECT —Gửi một gói lỗi trở lại hệ thống đã gửi gói, sau đó hủy gói. Mục tiêu này hữu ích nếu bạn muốn thông báo cho hệ thống gửi gói khớp về sự cố.

❑ Từ chối ping

- `iptables -A OUTPUT -p icmp --icmp-type -j REJECT`
- `iptables -A INPUT -p icmp --icmp-type -j DROP`

❑ Cho phép yêu cầu ping và phản hồi iptables đang được cấu hình để cho phép tường lửa gửi các yêu cầu phản hồi ICMP (ping) và ngược lại, chấp nhận các phản hồi phản hồi ICMP dự kiến.

- `iptables -A OUTPUT -p icmp --icmp-type echo-request -j ACCEPT`
- `iptables -A INPUT -p icmp --icmp-type echo-reply`

❑ Cho phép cả cổng 80 và 443 cho máy chủ web bên trong:-j ACCEPT

- `iptables -A FORWARD -s 0/0 -i eth0 -d 192.168.1.58 -o eth1 -p TCP --sport 1024:65535 -m multiport --dport 80,443 -j ACCEP`

❑ Lưu lượng truy cập trả về từ máy chủ web được phép, nhưng chỉ mở các phiên:

```
iptables -A FORWARD -d 0/0 -o eth0 -s 192.168.1.58 -i eth1 -p TCP \-m state --state ESTABLISHED -j ACCEPT
```

❑ Thiết lập số lượng tối đa các gói SYN iptables đang được cấu hình để cho phép tường lửa chấp nhận tối đa 5 gói TCP/SYN mỗi giây trên giao diện eth0.

```
iptables -A INPUT -p tcp --syn -m limit --limit 5/s -i eth0 -j ACCEPT
```

- Nếu có hơn 5 gói SYN mỗi giây, các gói sẽ bị loại bỏ.
- Nếu nguồn/đích cảm thấy các gói bị loại bỏ, nó sẽ gửi lại ba lần
- Nếu tiếp tục loại bỏ sau 3 gói đặt lại, nguồn sẽ giảm tốc độ gói.

- ☐ Cài đặt Firewall IPTable: (theo mô hình tham khảo sau)
- ☐ Thực hành FILTER: (Hình 1) Cho phép/ cấm các giao thức ICMP (ping), HTTP (web),
- ☐ FTP, telnet
 - Đi vào LAN: INPUT
 - Từ mạng LAN ra: OUTPUT
 - Chuyển tiếp gói tin: FORWARD

❑ Filter

- Out: `iptables -A OUTPUT -p icmp -j REJECT (DROP)`
- In: `iptables -A INPUT -p icmp -j REJECT (DROP)`

❑ Forward:

- Thiết lập default route (allow forward packet): `sysctl -w net.ipv4.ip_forward=1`
- Configure: `iptables -A FORWARD -d <Ip_des>.... ACCEPT`
- PC source, destination: Gateway side

☐ Set up IDS with Snort

- Download and install Snort
- Database: MySQL – install, create, GRANT....
- Graphic Interface for Snort:
- Web server, PHP
- pear
- ADODB: <http://nchc.dl.sourceforge.net/sourceforge/adodb/>
- BASE: <http://nchc.dl.sourceforge.net/sourceforge/secureideas/base-1.4.2.tar.gz>

☐ Set up attacker machine (DOS, Brute Force,....)

- Ping: ping, DDOS: hping3, Brute Force – using Hydra (telnet, ftp, http...)

```
$ nano /etc/snort/snort.conf
```

```
ipvar HOME_NET <IP/subnetmask>
```

```
ipvar EXTERNAL_NET !$HOME_NET
```

```
var RULE_PATH /etc/snort/rules
```

```
var SO_RULE_PATH /etc/snort/so_rules
```

```
var PREPROC_RULE_PATH /etc/snort/preproc_rules
```

```
var WHITE_LIST_PATH /etc/snort/rules
```

```
var BLACK_LIST_PATH /etc/snort/rules
```

\$ snort -T -c /etc/snort/snort.conf

```
--== Initialization Complete ==--

o'-'-)*-
  )~
  '
  '

-*> Snort! <*-
Version 2.9.8.0 GRE (Build 229)
By Martin Roesch & The Snort Team: http://www.snort.org/contact#team
Copyright (C) 2014-2015 Cisco and/or its affiliates. All rights reserved.
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.7.4
Using PCRE version: 8.35 2014-04-04
Using ZLIB version: 1.2.8

Rules Engine: SF_SNORT_DETECTION_ENGINE Version 2.4 <Build 1>
Preprocessor Object: SF_DCERPC2 Version 1.0 <Build 3>
Preprocessor Object: SF_POP Version 1.0 <Build 1>
Preprocessor Object: SF_IMAP Version 1.0 <Build 1>
Preprocessor Object: SF_MODBUS Version 1.1 <Build 1>
Preprocessor Object: SF_SIP Version 1.1 <Build 1>
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>
Preprocessor Object: SF_SSLPP Version 1.1 <Build 4>
Preprocessor Object: SF_DNS Version 1.1 <Build 4>
Preprocessor Object: SF_GTP Version 1.1 <Build 1>
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>
Preprocessor Object: SF_SSH Version 1.1 <Build 3>

Snort successfully validated the configuration!
Snort exiting
root@pc:~#
```

\$ /usr/local/bin/snort -A console -c /etc/snort/snort.conf -i eth0

```
o"~  
    -*) Snort! <*-  
Version 2.9.8.0 GRE (Build 229)  
By Martin Roesch & The Snort Team: http://www.snort.org/contact#team  
Copyright (C) 2014-2015 Cisco and/or its affiliates. All rights reserved.  
Copyright (C) 1998-2013 Sourcefire, Inc., et al.  
Using libpcap version 1.7.4  
Using PCRE version: 8.35 2014-04-04  
Using ZLIB version: 1.2.8  
  
Rules Engine: SF_SNORT_DETECTION_ENGINE Version 2.4 <Build 1>  
Preprocessor Object: SF_DCERPC2 Version 1.0 <Build 3>  
Preprocessor Object: SF_POP Version 1.0 <Build 1>  
Preprocessor Object: SF_IMAP Version 1.0 <Build 1>  
Preprocessor Object: SF_MODBUS Version 1.1 <Build 1>  
Preprocessor Object: SF_SIP Version 1.1 <Build 1>  
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>  
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>  
Preprocessor Object: SF_SDF Version 1.1 <Build 1>  
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>  
Preprocessor Object: SF_SSLPP Version 1.1 <Build 4>  
Preprocessor Object: SF_DNS Version 1.1 <Build 4>  
Preprocessor Object: SF_GTP Version 1.1 <Build 1>  
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>  
Preprocessor Object: SF_SSH Version 1.1 <Build 3>  
Commencing packet processing (pid=4653)
```


❑ Create rule icmp – ping:

```
$ nano /etc/snort/rules/icmp.rules
```

```
alert icmp any any -> $HOME_NET any (msg:"Co ai do dang ping";
```

```
sid:10000001; rev:001;)
```

❑ Add rule path in snort.conf

```
$ nano /etc/snort/snort.conf
```

```
include $RULE_PATH /etc/snort/rules/icmp.rules
```

❑ At attacker: *ping <IP_máy IDS>*

❑ At IDS:

```
Commencing packet processing (pid=4713)
12/26-22:46:12.921834  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.17 -> 192.168.1.11
12/26-22:46:12.921884  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.11 -> 192.168.1.17
12/26-22:46:13.911806  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.17 -> 192.168.1.11
12/26-22:46:13.911851  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.11 -> 192.168.1.17
12/26-22:46:14.878252  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.17 -> 192.168.1.11
12/26-22:46:14.878272  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.11 -> 192.168.1.17
12/26-22:46:15.872077  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.17 -> 192.168.1.11
12/26-22:46:15.872118  [**] [1:10000001:1] Co ai do dang ping [**] [Priority: 0] {ICMP} 192.168.1.11 -> 192.168.1.17
```

☐ Create rule dos – hping3:

\$ nano /etc/snort/rules/dos.rules. Ex:

*alert tcp any -> \$HOME_NET 80 (msg:"DDOS GET";content:"GET / HTTP";
flow:to_server, established; threshold: type threshold, track by_src,
count 30, seconds 30; sid:1000004;)*

☐ Add rule path in snort.conf

\$ nano /etc/snort/snort.conf

include \$RULE_PATH/dos.rules

☐ At attacker: hping3 ... <IP_máy IDS>

☐ At IDS: có thông báo "DDOS GET"

- ☐ Thực hiện tấn công scan port : Sử dụng nmap trên máy Kali Linux
- ☐ Thiết lập rule trên máy IDS
- ☐ Quan sát và phát hiện tấn công

- ☐ Lấy mật khẩu dùng Hydra: Sử dụng Hydra trong Kali lấy mật khẩu các dịch vụ telnet, ftp, http
- ☐ Thiết lập rule trên máy IDS
- ☐ Quan sát và phát hiện tấn công

- ☐ Thực hiện tấn công SQL Injection (trong bài Lab an toàn CSDL): Sử dụng DVWA
- ☐ Thiết lập rule trên máy IDS
- ☐ Quan sát và phát hiện tấn công

AN TOÀN THÔNG TIN (INSE330380)

Kết thúc Lab chương 6

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn